PulseFitness.ai — Security Posture

Pen-test readiness & control summary — prepared for external tester + board review

Generated 23 Jul 2026 · Checklist v1.3 · Confidential

STATUS: READY FOR EXTERNAL PENETRATION TEST

All 33 baseline findings (F-01 to F-33) closed and regression-tested. A 2026-06 focused audit of the newer surfaces (Inventory & Distribution, Dealer/Logistics/Staff portals, Customer Deliveries, public pricing) added SEC-001 to SEC-003 — all resolved or documented. No open High/Critical remain.

2026-06 focused audit — new surfaces

SEC-001 HIGH	FIXED & VERIFIED — portal tokens scoped out of operator APIs
SEC-002 MEDIUM	BY DESIGN — logistics on-site sign-off is a gated write path
SEC-003 LOW	FIXED — idempotency key on Stripe checkout create

Core controls (OWASP Top 10 + LLM Top 10)

Access control	Org-scoped queries; RBAC; 404 on cross-tenant; portal-token isolation
Authentication	bcrypt (cost 12), JWT HS256 + revocation, account lockout, login rate-limit
Injection / XSS	Parameterised Mongo; bleach sanitisation; server-rendered PDFs
SSRF	Always-on guard (ssrf_guard.py); internal-range denylist
CORS	Env allow-list (CORS_ORIGINS); wildcard rejected in production
AI / LLM	Prompt-injection guard, output sanitisation, per-tenant token budgets
Payments	Stripe webhook signature + idempotency; server-side price resolution
Multi-tenant	organization_id on every collection; per-site 403 isolation

Set in the test/prod environment before kickoff

ENFORCE_MASTER_ADMIN_MFA=true · ENFORCE_EMAIL_RECIPIENT_VALIDATION=true · STRICT_AV_MODE=true · EXPOSE_API_DOCS=false · STRIPE_WEBHOOK_SECRET=<set> · JWT_SECRET=<64-hex>. Helper: scripts/toggle_pentest_flags.sh.

Accepted limitations (signed off)

Shared preview/prod secrets (platform tier — mitigated by org segregation); Twilio SMS mocked; credential-blocked integrations (Sicon/DocuSign/Outlook) return not_configured. These are expected and should not be logged as findings.